PLAYBOOK DE RESPUESTA

PB-03 | Cambio en archivos críticos (FIM)

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Controlar cambios en configuración de la API de pagos sin confundir despliegues autorizados con alteración maliciosa.

02. Disparador, fuente y umbral

Wazuh syscheck / FIM sobre /opt/pagoclaro/api/config/.env, rutas de despliegue y archivos de autenticación de Ubuntu. Umbral propuesto: cualquier cambio no autorizado en .env se revisa de inmediato.

03. Severidad inicial y promoción

Alta si archivo de producción modificado fuera de ventana o sin autorización; Crítica si hay extracción de secretos o web shell; Baja/Media ante cambio autorizado.

04. Triage: validación paso a paso

1. Identificar archivo, agente C05-SRV-03, hash anterior/posterior y tipo de cambio.
2. Cotejar ventana de despliegue y autorización de TI.
3. Consultar usuario/proceso de escritura cuando la telemetría lo permita.
4. Revisar cambios simultáneos en servicios, procesos y conexiones al núcleo transaccional.
5. Determinar si la diferencia compromete claves, endpoint o credenciales.

05. Contención autorizada a N1

- Preservar captura FIM y hash; avisar a responsable del API.
- Solicitar a N2 revisión del servicio; no editar ni restaurar archivo en N1.

06. Acciones no autorizadas a N1

- No revertir configuración ni reemplazar .env.
- No copiar al informe secretos ni tokens de pagos.

07. Evidencia mínima preservada

- syscheck: ruta, acción, integridad, hashes, usuario, hora, rule.id si aparece.
- Comparación de autorización/documentación de cambio sin exponer secretos.

08. Escalamiento obligatorio a N2

Cualquier cambio no autorizado a .env de la API, binarios o secretos en producción; sospecha de ejecución de código.

09. Criterios de cierre técnico

Validado cambio aprobado y hash esperado, o escalado con preservación de evidencia.

10. Mejora continua

Limitar rutas de FIM a activos críticos y añadir alertas sobre permisos y llaves.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-03 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.